Security incident report

Section 1: Identify the network protocol involved in the incident
Based on the tcpdump logs, three key network protocols were involved in this incident: 1. **DNS (Domain Name System):** Used to resolve the domain names (`yummyrecipesforme.com` and the malicious `greatrecipesforme.com`) into IP addresses. 2. **TCP (Transmission Control Protocol):** Used to establish a reliable connection between the user's machine and the web servers via the 3-way handshake (Flags [S], [S.], [.]). 3. **HTTP (Hypertext Transfer Protocol):** Used at the application layer to request and transfer the website data and the malicious file (HTTP: GET method).

Section 2: Document the incident
A former employee executed a brute force attack against the admin panel of `yummyrecipesforme.com`. The attacker successfully gained access because the administrator account was still using a default password, and there were no security controls in place to limit login attempts. Upon gaining access, the attacker modified the website's source code by embedding a malicious JavaScript function. When legitimate customers visited the site, this script prompted them to download what appeared to be an executable browser update or a file for free recipes. Investigation in a sandbox environment using tcpdump confirmed that once the file was executed, it installed malware that redirected the user's browser HTTP traffic to a fake, malicious website (`greatrecipesforme.com`) and severely degraded the performance of their computers.

Section 3: Recommend one remediation for brute force attacks
Recommendation: Enforce a mandatory password change upon first login and implement an Account Lockout Policy (limiting the number of login attempts). **Explanation:** This multi-layered approach addresses both the root cause and the method of the attack. The mandatory password change directly eliminates the vulnerability exploited in this incident by ensuring that default administrative credentials cannot be maintained. Combined with an account lockout policy—which temporarily disables an account after a small number of failed attempts (e.g., 3 or 5)—the system will completely neutralize automated brute-force tools, making unauthorized access virtually impossible.